

Phishing Awareness and Email Security Policy

Created for: Shameless Ltd.

Created by: Gill Ltd.

Version 1.2

Date: 05/08/2024

Template provided by SANS Institute

(<https://www.sans.org/information-security-policy/?page=2>)

Confidential

OVERVIEW

Emails are often used in the business setting for communication and transmittance of data. Misuse of email can post many legal, privacy and security risks, emphasizing the importance for users to understand the appropriate use of electronic communications. Scams can be sent to Shameless email accounts, often in the form of phishing attacks that masquerade in order to compromise company systems. In order to protect Shameless's assets, all employees need to defend the integrity and confidentiality of Shameless's resources.

PURPOSE

The Phishing Awareness and Email Security policy is designed to: communicate to employees what is acceptable in terms of company email use, make employees aware that social engineering attacks occur, and that there are procedures in place for detection of potential scams. Employees will be able to understand their importance at maintaining Shameless's security posture, identify suspicious emails, and who to contact in the case of a potential attack. Furthermore, employees will be able to make the best choice when being pressured into sharing sensitive information.

SCOPE

The scope of the Phishing Awareness and Email Security policy will include all employees of Shameless, along with contractors and agents working on Shameless's behalf.

POLICY

1. All use of email must be consistent with Shameless policies and procedures of ethical conduct, safety, compliance with applicable laws and proper business practices.
2. Shameless email accounts should be used primarily for Shameless business related purposes; personal communication is permitted on a limited basis, but non-Shameless related commercial uses are prohibited.
3. Shameless may monitor messages without prior notice. Shameless is not obliged to monitor email messages.
4. Users are prohibited from automatically forwarding Shameless emails to a third party email system. Individual messages which are forwarded by the user must not contain Shameless confidential information.
5. Sensitive information of Shameless will not be shared with an unauthorized individual.
 - a. Techniques and phrases like "urgent matter" or threatening from "higher-level management" will not sway Shameless employees into sending information.

- b. Requests to release information about Shameless resources to a third-party will not be obeyed.
 - c. Methods like ego and vanity persuasion through email will not allow for sharing of Shameless information.
- 6. URL links sent to a Shameless email will not be accessed without proper evaluation of the sender and information provided in the email.
 - a. Personal information will not be shared through one of these links, especially regarding Shameless information.
- 7. Employees must complete a Phishing Awareness course within 30 days of employment. Employees must pass subsequent exam, or must retake until passing with an acceptable score. The course must be taken every six months by those outlined in the scope, along with the passing of any subsequent exam.
- 8. If any person defined under the scope examines email behavior mentioned in number 5 or 6 above, the identity of the requester **MUST** be determined before continuing communication. If unable, the Help Desk has to be contacted. The Help Desk must contact the Head of IT if suspicious activity is confirmed.
 - a. In the case the Help Desk is unavailable, the supervisor must be contacted before the end of the business day. If the supervisor is unavailable, the Head of IT must be contacted before the end of the business day.

POLICY COMPLIANCE

Monitoring compliance of the Phishing Awareness and Email Security policy includes periodic walk-thrus, video monitoring, business tool reports, internal and external audits, and feedback to the policy owner. Fake emails will be sent periodically in order to gauge the response of employees. A six-month renewal is required by each employee to ensure the policy is being followed and understood. Any exception to the above policy must be approved by the information security team in advance. Failure to comply with the above policy will result in disciplinary action. Purposeful ignorance to potential phishing emails can lead to permanent termination of employment, depending on frequency and severity.

VERSION HISTORY

Date	Author	Version	Description
05/03/2024	Sampy Gill	1.0	Created title page and outline of subsection
05/05/2024	Sampy Gill	1.1	Completed Overview, Purpose, and Scope subsections

05/06/2024	Sampy Gill	1.2	Completed Policy, Policy Compliance subsections
------------	------------	-----	---